

Evaluación de Seguridad en sentencias Microsoft SQL Server (MS-SQL) mediante IA

Juliana Briceño - Mariana Malagón - Jimmy Mancera - Escuela Colombiana de Ingeniería Julio Garavito

Estado del arte:

En la ciberseguridad corporativa y la gobernanza de datos, la gestión de la seguridad en la ejecución de consultas y transacciones SQL es un pilar crítico. Las bases de datos relacionales albergan los activos más sensibles de la organización, y la ejecución de scripts por parte de usuarios privilegiados (como DBAs, desarrolladores o terceros) representa un vector de riesgo elevado. Tradicionalmente, la validación de estas ejecuciones se ha apoyado en revisiones manuales, políticas de acceso rígidas o herramientas de monitoreo pasivo. Sin embargo, la creciente frecuencia y complejidad de las operaciones ha saturado la capacidad de los analistas de seguridad y auditores, dificultando la detección temprana de consultas maliciosas o no autorizadas sobre objetos críticos sin interferir con la continuidad del negocio.

1. Enfoques y soluciones actuales

Las tecnologías de Monitoreo de Actividad de Bases de Datos (Database Activity Monitoring - DAM) y los Firewalls de Aplicaciones Web (WAF) han estandarizado la captura de eventos y la protección perimetral. Aunque estas plataformas ofrecen registros detallados e inspección basada en firmas o expresiones regulares, presentan limitaciones estructurales cuando se requiere evaluar la intención semántica de una consulta, el impacto real sobre objetos sensibles o la correlación de la telemetría de red con las políticas de negocio. El estado actual de la industria se articula principalmente en tres enfoques:

Monitoreo de actividad y auditoría tradicional (Imperva, IBM Guardium, audit logs nativos): Permiten registrar la actividad de la base de datos y generar alertas ante desviaciones volumétricas o sintácticas conocidas. No obstante, operan de forma predominantemente reactiva, generan un alto volumen de falsos positivos debido a su rigidez normativa y carecen de comprensión semántica profunda sobre el contexto y la intención de la transacción.

Herramientas de análisis de código y WAF con IA (SAST/DAST, Cloudflare, FortiWeb): Emplean algoritmos para detectar patrones sintácticos de inyección SQL (SQLi) en el tráfico web o en el código fuente. Aunque mitigan vulnerabilidades externas conocidas, no están diseñadas para evaluar ejecuciones legítimas en tiempo de ejecución (runtime) realizadas por usuarios internos privilegiados, ni contrastan la consulta contra la matriz de activos sensibles o el perfil de rol.

Revisiones manuales y auditorías especializadas de scripts (DBAs y equipos de seguridad): Combinan el criterio experto para evaluar consultas complejas antes de su ejecución en entornos productivos. Sin embargo, este proceso genera cuellos de botella operativos, depende de revisiones por muestreo, lo que deja abiertas brechas de seguridad, y exige un esfuerzo insostenible y costoso para los equipos de auditoría.

2. Brecha identificada

La mayoría de las soluciones actuales abordan el problema de forma fragmentada: inspeccionan las sentencias antes de ejecutarse sin entender el contexto del usuario y de forma manual, o auditan la transacción de forma reactiva sin capacidad de interpretar en lenguaje natural el impacto semántico de lo ejecutado. Además, los sistemas DAM tradicionales muestran resultados y alertas en lenguaje muy técnico dejando de lado el lenguaje natural.

3. Oportunidad de Innovación y Justificación del Proyecto

Para resolver la brecha entre la prevención rígida y la auditoría manual costosa, este proyecto propone un modelo unificado de evaluación de seguridad en ejecuciones MS-SQL mediante IA, articulando un control contextual proactivo de sentencias y reactivo de transacciones.

El valor diferencial de este desarrollo radica en su enfoque semántico dual y adaptativo, donde la inteligencia artificial actúa como mecanismo de apoyo para interpretar el contexto y explicar los riesgos identificados. Este modelo opera en dos momentos:

En la fase proactiva: Analiza la estructura e intención de la consulta SQL antes de su ejecución. Apoyado en reglas de negocio (tipo de operación, rol del usuario y criticidad de los objetos afectados), el sistema identifica posibles riesgos de seguridad y determina si la sentencia requiere una validación profunda adicional.

En la fase reactiva: Analiza de forma masiva la información transaccional (IP origen/destino, usuario, aplicación y sentencia). Al contrastar estos datos con listas blancas y perfiles autorizados, genera informes de criticidad explicados en lenguaje natural.

Este enfoque de defensa en profundidad no solo optimiza radicalmente los tiempos de revisión y reduce el margen de error humano, sino que proporciona una arquitectura accesible para dar cumplimiento a los controles de gestión de acceso, segregación de funciones y monitoreo continuo.

Delimitación motor de BD: La implementación y validación del modelo propuesto se delimitará a sentencias MS-SQL. Esta decisión estratégica busca garantizar que la investigación tenga una aplicabilidad directa y resuelva necesidades reales en el contexto empresarial e institucional colombiano, basándose en tres factores clave:

Alta adopción corporativa: MS-SQL es el motor de datos empresarial más usado en Colombia particularmente en los sistemas ERP y de software contable con mayor instalación a nivel nacional (tales como SIIGO, Novasoft y Helisa).

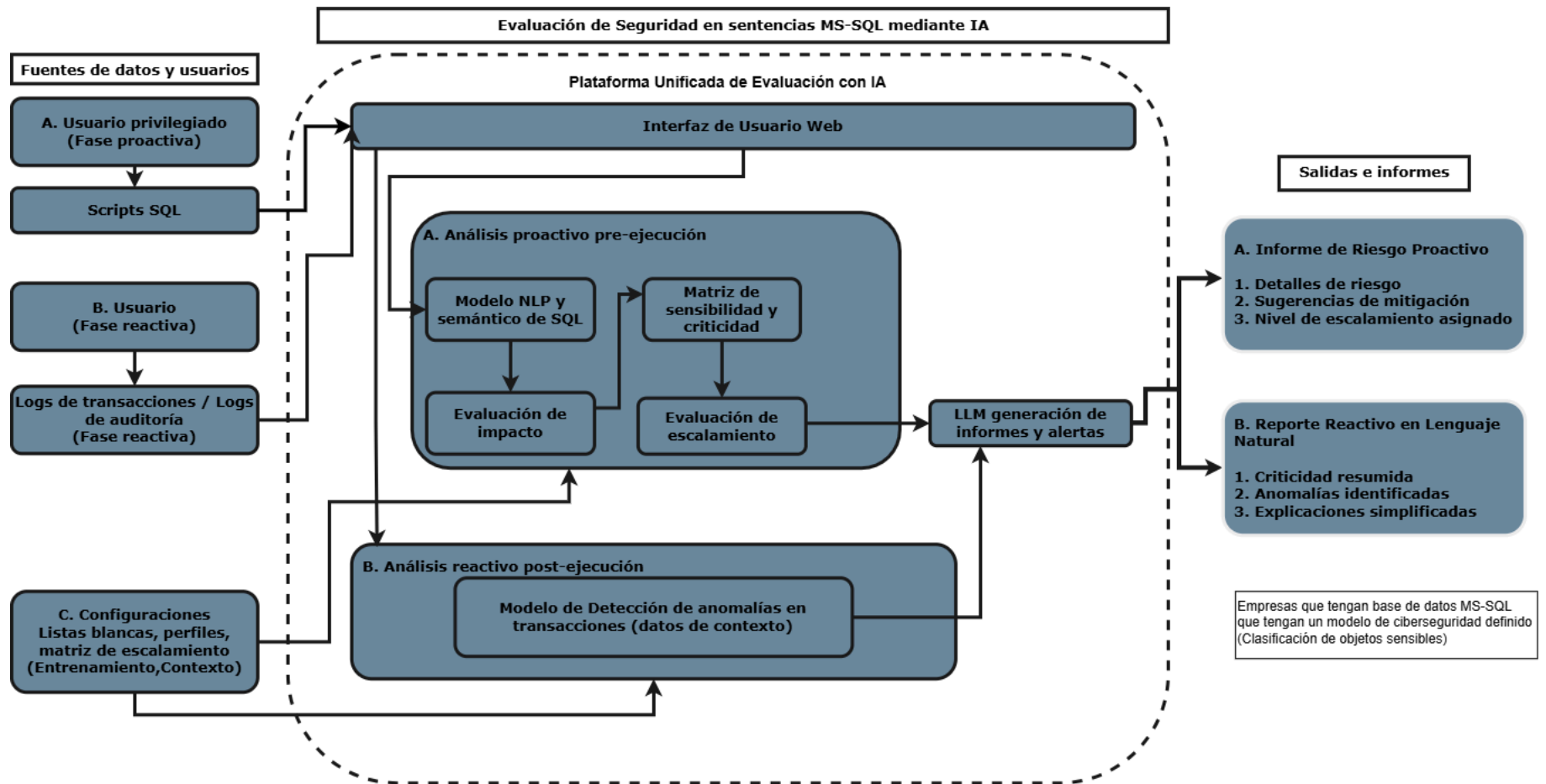
Alineación normativa: El motor ofrece soporte nativo avanzado para auditoría y cifrado transaccional. Esto facilita el cumplimiento de los estrictos requerimientos de seguridad exigidos por entidades reguladoras locales, como la Superintendencia Financiera y de Salud, sin depender de integraciones de terceros.

Ecosistema y migración a la nube: La adopción de MS-SQL está fuertemente respaldada por los convenios marco del Estado colombiano y de grandes conglomerados comerciales para sus procesos de modernización e infraestructura en la nube (Azure).

Por lo tanto, especializar el modelo de Inteligencia Artificial en la interpretación del dialecto propietario Transact-SQL (T-SQL) asegura que la solución de seguridad diseñada posea un alto índice de transferibilidad técnica, respondiendo directamente a los riesgos de la infraestructura que soporta gran parte de la operación corporativa del país.

Fuentes consultadas: Varonis (2025), "What is DAM?"; IEEE (2026), *SQL Injection Detection Based on LLMs*; Kim & Lee (2026), *SQL Injection in LLM-Generated Queries*, IEEE Access; "LLMs for Security Operations Centers: A Survey", arXiv:2509.10858; ISO/IEC 27001:2022 Anexo A, control 5.3 Segregation of Duties.

Arquitectura



<https://drive.google.com/file/d/1hoVu6eq5Ngx3K6eiKjfQ8nyJz3H3J18Z/view?usp=sharing>

Demo técnico

La demostración exhibirá el modelo dual en acción: primero mediante el análisis proactivo de un script SQL para mitigar riesgos con sus recomendaciones antes de su ejecución, y segundo, a través de la evaluación reactiva de transacciones ejecutadas, traduciendo la telemetría técnica a un informe en lenguaje natural.

Aplicación o aporte

El valor operativo de este modelo radica en la reducción drástica de tiempos de respuesta y el blindaje financiero al reducir la revisión de scripts de horas a segundos, el modelo habilita un entorno operativo ágil previniendo incidentes en bases de datos que superan en organizaciones en promedio el millón de registros, ahorrando a la empresa los 160 dólares que cuesta en promedio la filtración de cada dato sensible.

Según informes de la industria (ej. *Cost of a Data Breach* de IBM), una brecha de datos cuesta en promedio \$4.8 millones de dólares y toma cerca de 258 días en ser identificada y contenida mediante auditorías reactivas. Al delegar la evaluación semántica a la IA, la solución transforma este paradigma: reduce el tiempo de revisión de scripts complejos de horas (el costoso cuello de botella humano de DBAs y SecOps) a milisegundos en su fase proactiva. Para las gerencias de TI y Seguridad, esto significa acelerar el despliegue a producción sin fricciones (DevSecOps) y adoptar una postura preventiva que, estadísticamente, ahorra a las organizaciones más de \$2.2 millones de dólares por incidente al mitigar corrupciones de datos, exfiltraciones y multas regulatorias antes de que el script logre ejecutarse.

¿De dónde salen estas cifras?

- **\$4.8 millones y 258 días:** Es el promedio global de costo y tiempo del ciclo de vida de una brecha de datos según el último reporte anual consolidado de IBM Security.
- **Ahorro de \$2.2 millones:** El mismo reporte demuestra que las empresas que utilizan Inteligencia Artificial y automatización de forma extensiva en su seguridad ahorran en promedio 2.2 millones frente a las que dependen de procesos manuales.
- **Horas vs. Milisegundos:** Es el argumento del costo operativo. Un ingeniero experto (DBA o Arquitecto) puede tardar entre 30 minutos y 2 horas rastreando el impacto de un script de 500 líneas con *JOINS* complejos en bases de datos legadas. La IA lo hace en tiempo real, liberando ese recurso costoso para tareas de mayor valor.
- **El costo por registro (\$160 USD):** en la Dark Web un ciberdelincuente puede vender un registro por apenas \$1 o \$5 dólares, **pero el costo para la empresa** por cada uno de esos registros filtrados es de **\$160 USD**. Este valor es la métrica oficial de IBM para el *Costo por Registro Comprometido* e incluye la investigación forense, notificaciones legales, multas regulatorias (SIC) y pérdida de clientes.
- **El costo total para la PYME (\$150,000 USD / ~500 millones COP):** Los reportes locales de ciberseguridad en Colombia (como NSIT) demuestran que un ataque exitoso a una pyme (ej. un e-commerce o pasarela de pagos) suma rápidamente esta cifra al juntar: lucro cesante por caída de plataforma, recuperación técnica de la

infraestructura, y sanciones por incumplir la Ley 1581 de protección de datos.

- **El impacto real:** a diferencia de un banco grande que absorbe una multa, para una pyme colombiana un golpe de 500 millones de pesos implica, estadísticamente, el cierre de la empresa en los siguientes 6 meses.